

AI THREAT ASSESSMENT WORKBOOK

Digital Content #5 — Ghost Agent: The Attack That Was Never There

Purpose: Assess your organization's exposure to Ghost Agent attacks — where a malicious AI agent executes an unauthorized task and self-terminates, leaving no forensic trace. Map the governance gap, assign ownership, and build a prioritized response plan.

01 Exposure Check

Answer Yes / No / Unknown for your environment. Every Unknown is a gap. Three or more Unknowns = this is your next tabletop agenda.

Question	Yes	No	Unknown / Gap	Notes
Do you have a current inventory of all production AI agents operating in your environment?	☐	☐	☐	
For each agent, is there a documented list of tools, APIs, and egress channels it is provisioned to call?	☐	☐	☐	
Do agents processing external documents or data sources have content inspection at the full parse layer (including metadata and non-rendered fields)?	☐	☐	☐	
Are agent sessions logged at the intent level — not just activity (what was called), but goal state (what was the agent attempting to accomplish)?	☐	☐	☐	
Do you have per-session behavioral baselines established for high-privilege agents?	☐	☐	☐	
Is there semantic monitoring on agent-to-webhook and agent-to-API outbound payloads?	☐	☐	☐	
Are agent privileges scoped at the task level within a session, not only at the role level?	☐	☐	☐	
Does your IR playbook include a defined scenario for suspected agent compromise with no forensic confirmation?	☐	☐	☐	

AGENT INVENTORY (list production agents, intake surfaces, and egress channels)

Agent Name / Role	Intake Source(s)	Egress Channels	Intent Logging?	Owner

02 Intake Surface Audit

Ghost Agent enters through content the agent is authorized to process. Injection lives outside the human-visible layer — in metadata, non-rendered markup, and structured parsing targets. Audit each intake surface against full-parse inspection requirements.

Question	Yes	No	Unknown / Gap	Notes
For each agent, have you mapped every external content source it is authorized to process?	☐	☐	☐	
Does content inspection occur at the full parse layer — including document metadata, hidden fields, and non-rendered markup?	☐	☐	☐	
Are intake sources from third parties assessed for injection risk surface separately from internal sources?	☐	☐	☐	
Is there a process for flagging documents with anomalous metadata or non-standard fields before agent processing?	☐	☐	☐	
Have you tested injection detection capability using simulated payloads embedded in document metadata?	☐	☐	☐	

INTAKE SOURCE REVIEW: For each high-privilege agent, document intake sources and inspection coverage

Agent	Intake Source	Content Type	Full-Parse Inspection?	Gap / Action

03 Detection Baseline

Standard monitoring is built for unauthorized access and persistent threats. Ghost Agent terminates normally — no malware, no persistence, no alert. Detection requires intent-level logging and behavioral baseline comparison.

Question	Yes	No	Unknown / Gap	Notes
Are agent sessions logged at the intent level, capturing goal state at each decision point — not only tool calls and API activity?	☐	☐	☐	
Do you have per-session behavioral baselines for each production agent role (session duration, tool call sequence, output volume, egress patterns)?	☐	☐	☐	
Is there alerting on statistical deviation from per-session behavioral baselines?	☐	☐	☐	
Does semantic monitoring on outbound payloads compare content against the expected schema for each agent's provisioned purpose?	☐	☐	☐	
Can your monitoring detect tool call sequences that are individually authorized but inconsistent with the agent's assigned task?	☐	☐	☐	
Is pre-termination state snapshot implemented for high-privilege agents to preserve execution context before session close?	☐	☐	☐	
Have you tested detection capability with simulated Ghost Agent scenarios (injection, secondary task, normal termination)?	☐	☐	☐	

04 Governance Gap — Who Owns What

Ghost Agent's access was authorized. The agent was the credential. Map ownership across the forensic, legal, and governance surface before an incident surfaces the gap.

Function	Owner (Name / Role)	Last Reviewed	Gap
Agent session forensic continuity and log retention			
Intent-level audit logging implementation and oversight			
Intake surface content inspection controls			
Incident response — suspected agent compromise (unconfirmed)			
Breach trigger definition — agentic access and scope violations			
Legal response — third-party disclosure with no forensic confirmation			
Task-scoped privilege enforcement and provisioning governance			

05 Five Questions for Your Next Executive Meeting

#	Question	Your Answer / Status
01	For every production AI agent: do we have an intent-level audit trail that would allow us to reconstruct what the agent was attempting to accomplish during any given session — not just what it called?	
02	If an agent were compromised during an ephemeral session and terminated normally, would our logging posture allow us to detect that something happened — and what is our evidentiary position if it cannot?	
03	Do our agent intake surfaces apply content inspection at the full parse layer — including metadata and non-rendered fields the agent processes but reviewers do not see?	
04	Does our IR program have a defined trigger and playbook for suspected agent compromise that cannot be forensically confirmed — and who owns that escalation?	
05	Are agents operating under task-scoped privilege restrictions at the session level, or does tool access remain constant regardless of the task being executed?	

06 Directives — Assign an Owner and a Date

#	Audience	Directive	Owner	Done By
01	CISO	Inventory all production AI agents. Document intake sources, egress channels, provisioned tool scope, and current logging posture. Assume the list is incomplete.		
02	CISO	Audit agent intake surfaces for full-parse content inspection. Every external content source processed without it is an open injection vector.		
03	CISO	Implement intent-level audit logging for all high-privilege agents. Activity logging alone is insufficient — you need goal state at each decision point.		
04	CISO	Redefine breach trigger criteria to include agentic scope violations — where an agent executes outside its provisioned purpose, regardless of whether access was technically authorized.		
05	CISO	Assign named governance ownership of agent session forensic continuity. If the answer is the infrastructure team, you have an accountability gap.		
06	CISO	Extend the third-party risk framework to cover agent intake sources. Every external content source in an agent queue needs an injection risk assessment.		
07	IR	Add a Ghost Agent scenario to your IR playbook: defined trigger, evidentiary escalation path, third-party notification assessment — including for cases where forensic confirmation is structurally impossible.		
08	IR	Develop intake forensics capability. Define retention requirements for agent intake content in full-parse form before you need to run the analysis.		
09	IR	Map agents by forensic gap severity: high egress + unvalidated external intake + no intent-level logging = highest exposure. Close from the top.		
10	IR	Run a cross-functional accountability exercise: if our agent were compromised in a session today and a third-party disclosure arrived six weeks from now, who detects it, who owns the response, and what do we tell the board?		

Assessment prepared by Matsui LLC · matsuihq.ai